Software Seguro

```
root@software-seguro:~# ./start_course.sh
```

Clase 2: Reconocimiento y Mapeo superficial

Curso Profesional de Ciberseguridad Web y Ethical Hacking

Repaso

Objetivos de la Sesión

Mapear vectores de ataque, evadir trampas perimetrales y entender la aplicación antes de enviar el primer payload.

¿Que es el Pentesting?

“El pentesting es una simulación **controlada** y **autorizada** de un ciberataque contra sistemas, redes o aplicaciones para **identificar**, **evaluar** y **corregir** sus **vulnerabilidades** de seguridad antes de que puedan ser explotadas por actores maliciosos.”

Tipos de Pentesting

Black Box

El pentester no recibe información previa sobre el sistema y simula un ataque externo real, no tiene acceso a credenciales, codigo, documentacion.

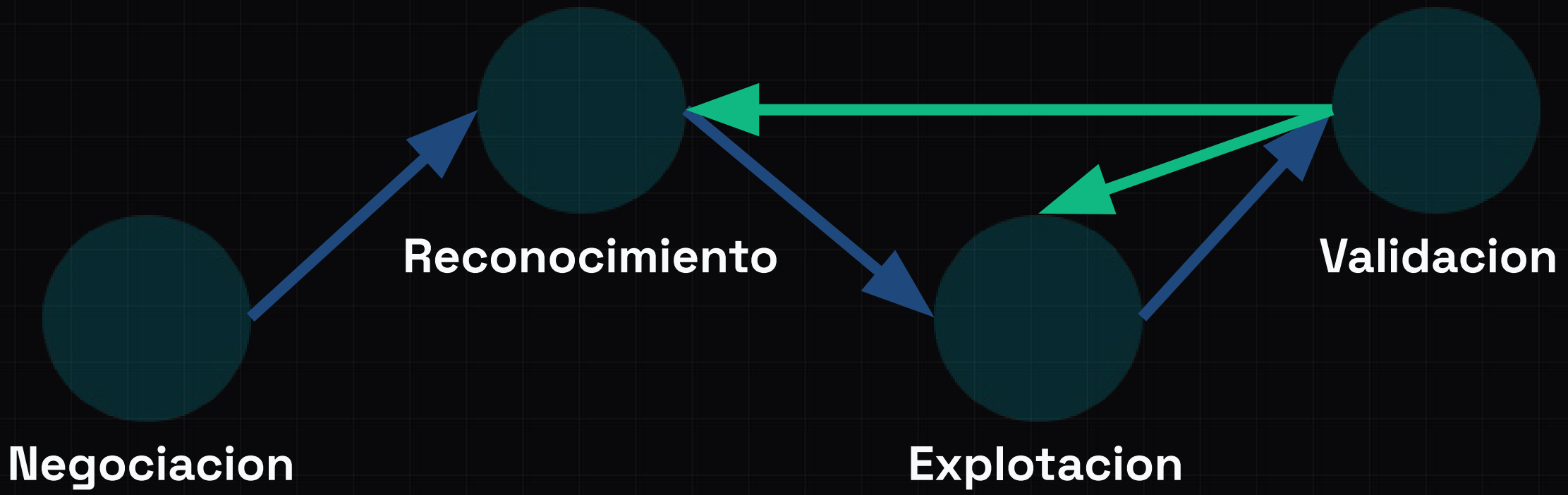
White Box

El pentester tiene acceso total a la información, incluyendo código fuente, diagramas de red y credenciales.

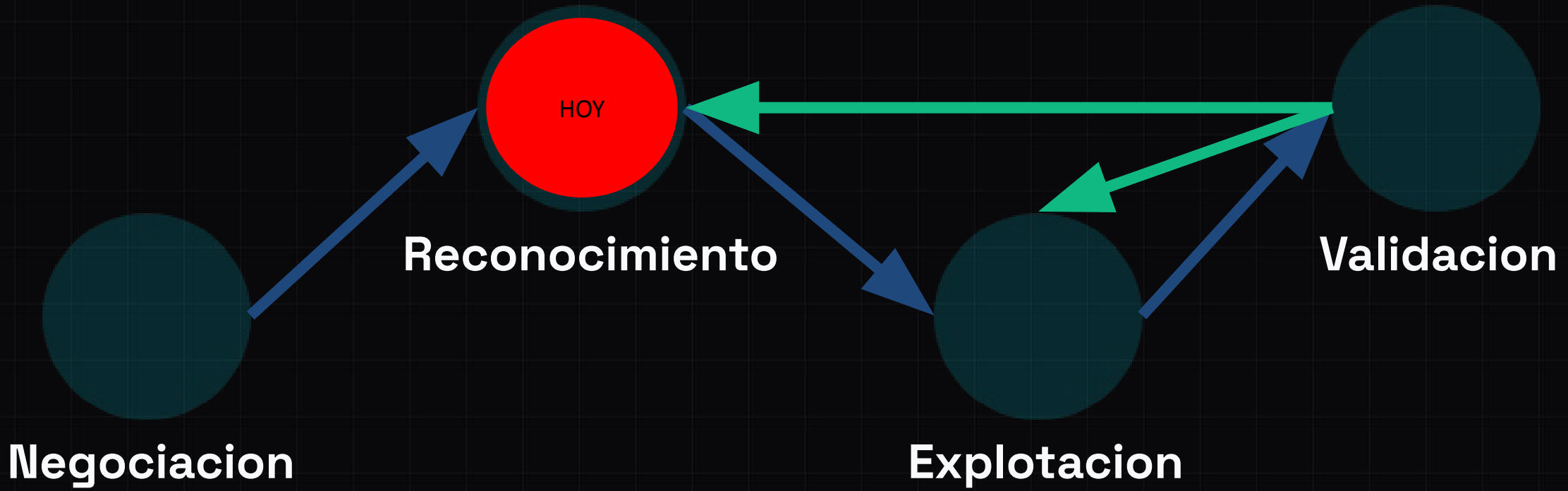
Gray Box

Es un punto intermedio donde se proporciona información parcial, como credenciales de usuario, documentacion.

Etapas del pentesting web



Etapas del pentesting web



Reconocimiento Pasivo vs Activo

Reconocimiento Pasivo

Condicion: Consulta exclusiva a fuentes públicas y terceros sin enviar tráfico directo al servidor de la víctima.

Fuentes: Certificate Transparency, Shodan, VirusTotal, Wayback Machine, Subfinder.

Ventaja: Indetectable para WAF/SIEM. Ideal para mapeo previo de alcance.

Reconocimiento Activo

Condicion: Interacción directa con la aplicación web y sus servicios para descubrir puertos, endpoints y comportamientos.

Herramientas: Nmap, ffuf, escaneos con Wappalyzer CLI.

Riesgo: Genera logs, puede disparar bloqueos de IP y exige RoE aprobado.

Reconocimiento pasivo en profundidad

- **Subfinder:** Herramienta diseñada para la enumeración pasiva de subdominios. No envía paquetes directos al servidor del objetivo, sino que interroga docenas de servicios externos y motores de búsqueda.

```
subfinder -d ejemplo.com -silent -o subdominios.txt
```

- **GAU (GetAllURLs):** Consulta índices históricos y proveedores de telemetría web encuentra rutas antiguas que el servidor todavía puede estar interpretando, endpoints de APIs deprecadas, archivos sensibles indexados en el pasado (.bak, .env, .sql) y parámetros en la query string

```
gau ejemplo.com --subs -o urls.txt
```

- **Exploit-DB:** Aloja y mantiene la colección oficial de Google Dorks conocida como GHDB.

- **Mas recursos:** crt.sh, bgp.he.net

Shodan: Inteligencia de Servicios

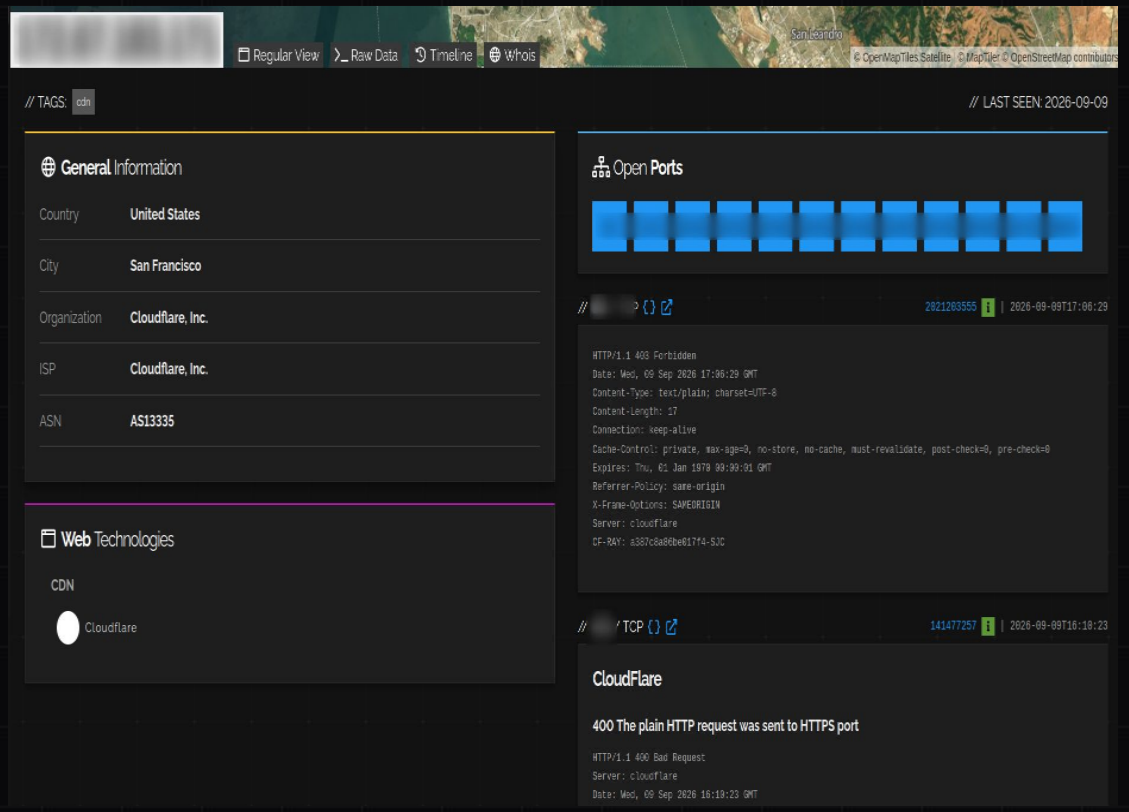
Visibilidad Sin Enviar Paquetes

> Shodan indexa banners de puertos abiertos en todo internet. Su extensión de navegador revela al instante la IP de origen y puertos expuestos del sitio visitado.

> Filtros clave para pentesting web: ssl:"target.com" y org:"Target Corp" para hallar paneles en puertos :8080 o :8443.

> **Extencion:** Shodan tiene una extensión muy amigable que permite rápidamente ver puertos abiertos la direccion IP y CVEs si los posee

> **Alternativa:** censys



Nmap y Content Discovery

> **Escaneo de Puertos con Nmap:** Identificar consolas alternativas y bases de datos expuestas. scanme.nmap.org.

```
sudo nmap -p- --open --min-rate 5000 -n target.com
```

```
nmap -sV -p 80,443 target.com
```

> **ffuf:** Es ultraligera, sumamente rápida y permite inyectar la palabra clave FUZZ en cualquier punto de la petición (rutas, cabeceras, parámetros POST o subdominios).

```
ffuf -u https://softwareseguro.com.ar/FUZZ -w Disco500/HACKLAB/SecLists/Discovery/Web-Content/common.txt -r -ac -c
```

> **feroxbuster:** Destaca por realizar recursión automática de directorios por defecto. Si encuentra /admin/, automáticamente inicia un nuevo fuzzing dentro de /admin/FUZZ sin necesidad de configuraciones complejas.

```
feroxbuster -u https://target.ar -w Disco500/HACKLAB/SecLists/Discovery/Web-Content/raft-small-words.txt -t 30 -d 2
```

Identifica frameworks, CMS y versiones

HTTPX

Es un probeador (sondeador) HTTP rápido y configurable

A diferencia de Subfinder y GAU, HTTPX realiza reconocimiento activo: envía peticiones HTTP/HTTPS reales contra una lista de dominios, subdominios o IPs

```
echo "softwareseguro.com.ar" | ~/go/bin/httpx
-title -tech-detect -status-code -follow-redirects
```

Wappalyzer

Es un motor de fingerprinting de tecnologías web (disponible como extensión de navegador o como herramienta de línea de comandos vía Node.js/CLI). Analiza cabeceras HTTP, variables JavaScript globales, estructuras de cookies, metatags HTML y rutas de scripts para detectar el stack técnico completo.

Escaneo de vulnerabilidades

- **Nuclei:** Un escáner de vulnerabilidades rápido y modular, Funciona enviando peticiones basadas en plantillas (templates en formato YAML) mantenidas por la comunidad de seguridad global.

```
nuclei -u https://softwareseguro.com.ar -severity medium,high,critical -o vulns_nuclei.txt
```

- **WPScan (Específico para WordPress):** Mapea la versión del núcleo (core) de WordPress, enumera los plugins y temas instalados (los principales vectores de ataque en este CMS) y comprueba vulnerabilidades conocidas cruzando los resultados con su base de datos de seguridad (WPVDB). También permite listar nombres de usuario válidos.

```
wpscan --url https://ejemplo.com --enumerate vp,vt
```

- **Nikto:** n escáner clásico de servidores web escrito en Perl que evalúa el servidor HTTP subyacente (Apache, Nginx, IIS). No busca exploits complejos de lógica de negocio, sino fallas de infraestructura:

```
nikto -h https://target.com.ar -output reporte_nikto.txt
```

Mapeo de logica de negocio, componentes y comportamiento

Navegar el "Happy Path": Comprender el uso normal de la plataforma antes de enviar payloads para modelar las suposiciones del programador.

Identificar flujos críticos: Identificar aquellos componentes que tienen que seguir una sucesión de pasos, realizan acciones críticas de creación, borrado, transacciones, obtención de datos sensibles PII.

Inputs identificables: ¿Que campos de carga existen? Buscar inputs que permitan carga de elementos, campos de texto, fechas, campos numericos, subida de imagenes, avatares, documentos.

Identificar procesos de reporting: Se pueden descargar o generar archivos en la aplicación? verificar los formatos válidos, validaciones en la interfaz, verificar que contenido y de dónde lo obtiene.

Identificar consultas con datos: Filtros de búsqueda, paginadores, buscar usuarios, productos, identificar la información que devuelve, y como la refleja en la interfaz.

Laboratorios de Software Seguro

Pasamos de la teoría a la práctica en plataformas reales

Asignación para el Hogar

Resolver y enviar los objetivos del Módulo II: Information Gathering y Reconocimiento

Ingresar a la plataforma de Software Seguro, en las opciones les aparecera el curso “Curso Profesional de Ciberseguridad Web y Ethical Hacking”, dentro del curso tienen los distintos módulos con sus objetivos que deberán enviar antes de la próxima sesión

¿Preguntas?

Fin de la Sesión 1. Nos vemos en los laboratorios.

https://softwareseguro.com.ar